

Retour de cellule — Risque / Conformité

Réf. : Réponse à la note DC/2026/01, rubrique 02 · 24 septembre 2026 (J2), 16:45, Europe/Paris (UTC+2)
Émetteur : Cellule Risque / Conformité · répondante : Essafi Amina
Destinataire : Reda El ghardegue, chef de cellule adjoint, Direction / Coordination
Copie : Belkhaouad Aya, cheffe de cellule et répondante
Objet : Obligations, engagements contractuels, données exposées et arbitrage rançon · Incident MIRAGE
Traitement : **prioritaire**

01 Obligations à examiner au regard des faits établis

Autorité / destinataire	Fondement	Condition de notification	Délai applicable	Informations manquantes pour conclure
DGSSI / maCERT (autorité nationale de cybersécurité)	Loi 05-20, art. 8 : l'entité « dès qu'elle prend connaissance d'un incident affectant la sécurité ou le fonctionnement de ses systèmes d'information, [doit] le déclarer à l'autorité nationale ». Art. 14 : applicable aux IIV. Art. 50 : amende de 100 000 à 200 000 DH pour manquement à la déclaration.	Incident avéré (rempli). AtlasGrid doit être entité publique ou IIV : statut non confirmé (secteur énergie, SCADA).	Sans délai , dès connaissance (T0 = J1 11:52). Pas de délai en heures dans la loi ; le décret 2-21-406 (art. 42) renvoie au référentiel DGSSI.	Acte de désignation IIV d'AtlasGrid ; identité de l'interlocuteur DGSSI (art. 6) ; référentiel DGSSI de déclaration (formulaire, canal). Même en cas de doute sur le statut, déclarer.
CNDP	Loi 09-08, art. 23 : obligation de protéger les données « contre [...] la diffusion ou l'accès non autorisé ». Art. 58 : 3 mois à 1 an et/ou 20 000–200 000 DH ; art. 64 : amendes doublées pour une personne morale. Aucun article n'impose de notifier une violation.	Données personnelles effectivement consultées ou extraites.	Pas de délai légal. Cible recommandée : 72 h depuis J1 14:27, soit avant J4 14:27 (référence : art. 33 RGPD).	Liste des fichiers sortis (Forensique) ; catégories et nombre de personnes ; traitements déclarés à la CNDP (art. 12, sinon art. 52 : 10 000–100 000 DH).
Personnes concernées (salariés, clients)	Loi 09-08, art. 3 : données « traitées loyalement et licitement ». Pas d'obligation explicite d'information après violation.	Risque réel : RIB, CIN, salaires, contacts ; menace de publication.	Dès que les catégories exposées sont confirmées.	Périmètre confirmé des données ; canal hors messagerie compromise.
Assureur (police cyber ou dommages, si souscrite)	Code des assurances (loi 17-99), art. 20 : l'assuré doit aviser l'assureur « dès qu'il en a connaissance, et au plus tard dans les cinq jours » de la survenance de tout sinistre de nature à entraîner sa garantie. La déchéance n'est pas opposable en cas de force majeure.	Existence d'une police couvrant le cyber (dommages, pertes d'exploitation, extorsion, frais de notification).	5 jours maximum depuis la survenance ; la survenance pouvant remonter à J-1 (exécution) voire J-21 (intrusion), déclarer aujourd'hui.	Existence et numéro de police ; garanties et exclusions ; accord préalable exigé avant tout paiement de rançon ou choix de prestataires ; franchise ; plafond.
Autorité sectorielle énergie	Réglementation sectorielle éventuelle.	Atteinte à l'exploitation énergétique.	À vérifier.	Existence d'une obligation de signalement sectorielle.

02 Engagements envers les clients — Chérifienne des Mines

Élément	Engagement déjà accepté ?	Ce que nous savons	Ce qu'il faut vérifier / faire
Disponibilité de 99,5 %	Invoqué par le client, non vérifié. Existe peut-être au contrat.	Le portail de facturation est inaccessible depuis J2 matin selon le client (possiblement plus tôt).	Lire la clause : service couvert (portail ou facturation), période de mesure , exclusions (maintenance, force majeure, attaque), remède (crédit de service, pénalité, résiliation), plafond de responsabilité.
Rétablissement « sous 24 heures »	Non : c'est une demande nouvelle. L'accepter créerait un engagement qui nous lierait (DOC, art. 230).	Continuité n'a pas encore donné de délai de reprise réaliste.	Ne pas promettre de délai sans validation de Continuité et de la Direction (consigne commune à Communication).
Explication écrite de l'incident	Demandée par le client ; obligation à vérifier au contrat (clause de notification).	Nous pouvons annoncer : incident de cybersécurité en cours, services de facturation touchés, cellule de crise mobilisée.	Réponse écrite factuelle, sans aveu de faute ni spéculation sur les données, validée par notre cellule ; prochain point daté.
Force majeure	À ne pas invoquer à ce stade.	DOC, art. 269 : fait que l'on « ne peut prévenir » et qui rend l'exécution impossible. L'absence de MFA sur le compte prestataire affaiblit fortement cet argument.	Réserver la question pour l'analyse juridique après la crise.

Ordre de grandeur de la clause (si elle existe) : 99,5 % autorise environ **3,6 h** d'indisponibilité par mois, **10,9 h** par trimestre ou **43,8 h** par an. Si la mesure est mensuelle, le seuil est **déjà dépassé** ; si elle est annuelle, il le sera après un peu moins de deux jours d'arrêt. D'où l'importance de lire la période de mesure avant de répondre.

03 Responsabilités contractuelles d'OasisNet

Point	Constat	Fondement	Ce qu'il manque / action proposée
Sécurité du compte d'administration	svc_oasisnet utilisé sans MFA alors que le profil de référence exige la MFA ; connexions de nuit, depuis l'étranger (A-02).	Loi 09-08, art. 23 al. 2 : AtlasGrid doit choisir un sous-traitant « qui apporte des garanties suffisantes » et « veiller au respect de ces mesures ». Loi 05-20, art. 10 : le prestataire d'un SI sensible respecte les règles de l'autorité.	Contrat d'infogérance : clauses de sécurité, MFA, comptes nominatifs, journalisation. AtlasGrid reste responsable envers la CNDP et les personnes ; recours ensuite contre OasisNet.
Sauvegardes	Même compte modifie la rétention Veeam à J-3 (A-05).	Contrat (obligations de moyens ou de résultat sur la sauvegarde) ; DOC, art. 263 : dommages-intérêts pour inexécution.	Périmètre de service, obligations de test et de restauration, localisation des sauvegardes.
Information et coopération	Deux messages minimisent (« rien n'indique que cela vous concerne », « anomalie de supervision ») ; renvoi aux « canaux contractuels ».	DOC, art. 231 : « tout engagement doit être exécuté de bonne foi ». Loi 09-08, art. 23 al. 3 : contrat de sous-traitance obligatoire.	Clause de notification d'incident et délai ; droit d'audit ; remise des journaux.
Responsabilité et assurance	Préjudice important (arrêt, rançon, notifications, clients).	Contrat : plafond de responsabilité, exclusions, assurance RC du prestataire.	Courrier de réserve de droits par écrit : demande des journaux, du rapport d'incident, de la liste des comptes et sous-traitants ; conservation des preuves. Pas de résiliation pendant la crise (dépendance pour la reprise).

04 Enjeux liés aux données potentiellement exposées

Source probable	Catégories de données	Personnes concernées	Risque pour les personnes	Statut
PAIE-01, partage paie	Salaires, RIB, CIN, n° CNSS, adresses	Tous les salariés	Fraude bancaire, usurpation d'identité, hameçonnage ciblé	À confirmer
Dossiers RH (partages, postes RH)	Contrats, évaluations, arrêts de travail (la pièce A-24 montre que des arrêts sont documentés)	Salariés	Atteinte à la vie privée. Les données de santé sont sensibles au sens de la loi 09-08 (art. 1) : régime renforcé.	À confirmer
Finance, ERP, facturation	IBAN fournisseurs, factures, contacts clients	Fournisseurs, grands comptes	Fraude au virement (voir A-23, déjà observée), hameçonnage	À confirmer
Messagerie (MSG-01 partiel), compte finance compromis (A-11)	Échanges internes et externes	Salariés, partenaires	Fraude au président, divulgation	À confirmer

Enjeux pour l'entreprise : sanctions 09-08 si la sécurité est jugée insuffisante (art. 58 et 64), réclamations des clients, chantage à la publication. **Pour conclure, il manque** : la liste des fichiers réellement sortis (le volume seul ne suffit pas), l'explication de l'écart 12,5 Go / 117,8 Go, la destination des flux, et une veille des sites de fuite de l'attaquant. Demandes adressées à la Forensique.

05 Éléments nécessaires à un arbitrage sur la rançon

Affirmation de l'attaquant	Vérification à ce stade	Statut
« Vos fichiers sont chiffrés »	23 / 40 serveurs chiffrés (A-13), extension .mirage	Confirmé
« Vos données ont été copiées »	Volumes sortants avérés (A-02, A-03) ; contenu non identifié	À confirmer
« Vos sauvegardes ont été détruites, il n'y a plus rien à restaurer »	Sauvegardes en ligne neutralisées (A-05) ; clichés locaux supprimés ; bandes hors ligne non vérifiées ; suppression des clichés ≠ destruction de toutes les sauvegardes	À confirmer
« Nous le saurons si vous prévenez les autorités »	Pression psychologique, aucun élément	Non étayé

Critère de décision	Éléments disponibles	Informations manquantes
Capacité de reprise sans payer	Dernier travail Veeam réussi à J-4 (à confirmer) ; SCADA et DC-02 intacts	État et intégrité des bandes LTO-9, test de restauration (Continuité) ; outil de déchiffrement public (projet No More Ransom)
Cadre juridique du paiement	Aucun texte trouvé interdisant expressément de payer une rançon au Maroc. L'Office des changes a déclaré en 2017 que les transactions en monnaies virtuelles enfreignent la réglementation des changes et sont passibles de sanctions. Un projet de loi sur les crypto-actifs (n° 42-25) est en préparation.	Avis juridique sur le paiement en BTC ; risque de financer un groupe criminel ; position de la police
Assurance	—	Couverture « extorsion » ; accord préalable de l'assureur ; prestataires imposés
Effet d'un paiement	Ne supprime aucune obligation (DGSSI, CNDP, clients) ; aucune garantie de suppression des données ni de non-récidive	—

Critère de décision	Éléments disponibles	Informations manquantes
Échéance	« 48:00:00 » à partir de l'apparition de la note (J2, petit matin)	Heure exacte de départ du compte à rebours (Forensique, A-04)

Sources des textes cités

- Loi 05-20 relative à la cybersécurité (art. 2, 6, 8, 10, 14, 50) : <https://bwcimplementation.org/sites/default/files/resource/loi%2005-20.pdf>
- Décret 2-21-406 (art. 42) : <https://static.lematin.ma/files/lematin/fichiers/articles/2021/08/cba35cb12f5e1a10edb4d6339fb28623.pdf>
- Loi 09-08 (art. 1, 3, 12, 23) : <https://www.cndp.ma/wp-content/uploads/2023/11/Loi-09-08-Fr.pdf>
- CNDP, infractions et sanctions (art. 52, 58, 64) : <https://www.cndp.ma/wp-content/uploads/2024/03/CNDP-loi-09-08-Liste-des-infractions-sanctions-fr.pdf>
- Code des assurances, loi 17-99 (art. 20), ACAPS : https://www.acaps.ma/sites/default/files/publication_documents/loi_ndeg_17-99_portant_code_des_assurances_dahir_ndeg_1-02-238_du_25_rejeb_1423_3_octobre_2002_telle_quelle_a_ete_modifiee_et_completee.pdf
- DOC (art. 230, 231, 263, 269), analyse citant les articles : <https://www.village-justice.com/articles/execution-contrat-epreuve-covid,36114.html>
- Office des changes et monnaies virtuelles (2017) : https://telquel.ma/2017/11/21/loffice-changes-interdit-lutilisation-du-bitcoin_1569648
- Code pénal, art. 607-3 et s. (UNODC) : https://www.unodc.org/cld/fr/legislation/mar/code_penal/chapitre_x/articles_607-3_607-4/articles_607-3_607-4.html